

# Requirement provenance — where each of the 82 features came from

**A mark means the source's published documentation evidenced this requirement. It does NOT mean the product has the feature, and a blank does NOT mean it lacks one.**

The research behind the gap matrix was a handful of published pages per vendor — enough to establish what the market expects a key management system to do, nowhere near enough to compare products feature by feature. A capability comparison would need a hands-on evaluation of each product, and this is not one.

|            |                                                |            |                                                    |
|------------|------------------------------------------------|------------|----------------------------------------------------|
| <b>THA</b> | Thales CipherTrust Manager                     | <b>FOR</b> | Fortanix Data Security Manager                     |
| <b>ENT</b> | Entrust KeyControl                             | <b>UTI</b> | Utimaco Enterprise Secure Key Manager              |
| <b>BLO</b> | Bloombase KeyCastle                            | <b>COS</b> | Cosmian / Eviden KMS                               |
| <b>SEC</b> | Securosys CyberVault KMS                       | <b>VLT</b> | HashiCorp Vault                                    |
| <b>CLD</b> | AWS KMS / Azure Managed HSM / Google Cloud KMS | <b>STD</b> | NIST SP 800-57, SP 800-152, OASIS KMIP 2.1 and 3.0 |
| <b>CAT</b> | Category baseline — no source named it         |            |                                                    |

*CAT is the honest residue: requirements no source in the research named, present because they are ordinary practice for a networked service that handles secrets. It never sits beside another code — the generator refuses to build if it does — so the CAT column counts exactly the requirements nothing evidenced, and those rows are marked in amber rather than left to hide among the others.*

*Marks are given strictly, and that costs blank cells. A vendor whose documentation describes audit logging has evidenced an audit trail, not a tamper-evident one, so it leaves the tamper-evidence row blank. Read a blank as “not seen in what was read”, never as “absent from the product”.*

## Key lifecycle and cryptography

| Requirement                                 | THA | FOR | ENT | UTI | BLO | COS | SEC | VLT | CLD | STD | CAT | Status  |
|---------------------------------------------|-----|-----|-----|-----|-----|-----|-----|-----|-----|-----|-----|---------|
| HSM-backed storage, keys never leave        | ●   | ●   | ●   | ●   | ●   | ●   | ●   | -   | ●   | ●   | -   | Covered |
| Full lifecycle state machine                | ●   | -   | ●   | -   | ●   | ●   | ●   | -   | -   | ●   | -   | Covered |
| Cryptoperiod enforcement                    | -   | -   | ●   | -   | -   | -   | -   | -   | ●   | ●   | -   | Covered |
| Automatic rotation                          | ●   | -   | ●   | ●   | -   | ●   | ●   | -   | ●   | -   | -   | Partial |
| Key lineage and versioning                  | ●   | -   | -   | -   | -   | -   | -   | ●   | ●   | -   | -   | Covered |
| Algorithm breadth                           | -   | -   | -   | -   | -   | ●   | ●   | ●   | -   | ●   | -   | Partial |
| Post-quantum (ML-KEM, ML-DSA, SLH-DSA)      | -   | -   | -   | -   | -   | ●   | ●   | -   | -   | ●   | -   | Gap     |
| Hardware RNG                                | -   | -   | -   | ●   | ●   | -   | -   | -   | -   | ●   | -   | Covered |
| Key derivation                              | -   | -   | -   | -   | -   | -   | -   | ●   | -   | ●   | -   | Covered |
| Key wrapping / secure import-export         | ●   | -   | -   | -   | ●   | -   | -   | ●   | ●   | ●   | -   | Covered |
| Split knowledge / M-of-N shares             | -   | ●   | -   | ●   | -   | -   | -   | ●   | -   | ●   | -   | Partial |
| Formal key ceremony                         | -   | -   | -   | -   | -   | -   | -   | ●   | -   | ●   | -   | Gap     |
| Bulk and batch operations                   | -   | -   | -   | -   | -   | -   | -   | -   | -   | ●   | -   | Partial |
| Verifiable destruction                      | ●   | -   | ●   | -   | -   | -   | -   | -   | -   | ●   | -   | Covered |
| Key-bound usage policy enforced in hardware | -   | -   | -   | -   | -   | -   | ●   | -   | -   | -   | -   | Gap     |

## Protocol and ecosystem integration

| Requirement                                 | THA | FOR | ENT | UTI | BLO | COS | SEC | VLT | CLD | STD | CAT | Status  |
|---------------------------------------------|-----|-----|-----|-----|-----|-----|-----|-----|-----|-----|-----|---------|
| KMIP server                                 | ●   | -   | ●   | ●   | ●   | ●   | ●   | ●   | -   | ●   | -   | Covered |
| KMIP interoperability certification         | -   | -   | -   | -   | ●   | -   | -   | -   | -   | ●   | -   | Gap     |
| KMIP 3.0                                    | -   | -   | -   | -   | -   | -   | -   | -   | -   | ●   | -   | Gap     |
| PKCS#11 provider for applications           | -   | -   | -   | ●   | ●   | ●   | ●   | -   | -   | -   | -   | Gap     |
| REST / JSON API                             | ●   | ●   | -   | ●   | -   | ●   | ●   | ●   | ●   | -   | -   | Gap     |
| Cloud BYOK (AWS, Azure, GCP)                | ●   | ●   | -   | -   | -   | -   | -   | -   | ●   | -   | -   | Gap     |
| Cloud EKM / XKS / hold-your-own-key         | -   | ●   | -   | -   | -   | -   | ●   | -   | ●   | -   | -   | Gap     |
| Database TDE integration                    | ●   | -   | ●   | -   | -   | ●   | ●   | -   | -   | -   | -   | Partial |
| Storage, backup and VM integrations         | -   | -   | ●   | -   | ●   | -   | ●   | -   | -   | -   | -   | Partial |
| Secrets management                          | ●   | ●   | ●   | -   | -   | -   | -   | ●   | -   | -   | -   | Partial |
| Tokenization / format-preserving encryption | ●   | ●   | -   | -   | -   | ●   | -   | -   | -   | -   | -   | Gap     |
| Certificate lifecycle                       | -   | -   | -   | -   | ●   | ●   | ●   | -   | -   | -   | -   | Partial |
| Encryption as a service (data-plane API)    | -   | -   | -   | -   | -   | ●   | -   | ●   | ●   | -   | -   | Partial |
| KMIP JSON and XML encodings                 | -   | -   | -   | -   | -   | ●   | -   | -   | -   | ●   | -   | Gap     |
| OpenAPI specification and generated clients | -   | -   | -   | -   | -   | ●   | -   | -   | ●   | -   | -   | Gap     |

## Identity and access control

| Requirement                          | THA | FOR | ENT | UTI | BLO | COS | SEC | VLT | CLD | STD | CAT | Status  |
|--------------------------------------|-----|-----|-----|-----|-----|-----|-----|-----|-----|-----|-----|---------|
| Per-identity authentication          | ●   | -   | -   | ●   | -   | ●   | -   | ●   | -   | -   | -   | Covered |
| Enterprise IdP — LDAP/AD, SAML, OIDC | -   | -   | -   | ●   | -   | ●   | -   | ●   | -   | -   | -   | Gap     |



## Operations and observability

| Requirement                     | THA | FOR | ENT | UTI | BLO | COS | SEC | VLT | CLD | STD | CAT | Status  |
|---------------------------------|-----|-----|-----|-----|-----|-----|-----|-----|-----|-----|-----|---------|
| Health and readiness probes     | -   | -   | -   | -   | -   | -   | -   | -   | -   | -   | ●   | Covered |
| Metrics                         | -   | -   | -   | -   | -   | -   | -   | ●   | -   | -   | -   | Covered |
| Structured logging              | -   | -   | -   | -   | -   | -   | -   | -   | -   | -   | ●   | Covered |
| Configuration-driven deployment | -   | -   | -   | -   | -   | -   | -   | -   | -   | -   | ●   | Covered |
| Administrative CLI              | -   | -   | -   | -   | -   | ●   | -   | ●   | -   | -   | -   | Covered |
| Web console                     | ●   | ●   | ●   | -   | ●   | ●   | ●   | -   | -   | -   | -   | Gap     |
| Self-service developer portal   | ●   | -   | -   | -   | -   | -   | -   | -   | -   | -   | -   | Gap     |
| Alerting                        | -   | -   | -   | -   | ●   | -   | ●   | -   | -   | -   | -   | Partial |
| Distributed tracing             | -   | -   | -   | -   | -   | ●   | -   | -   | -   | -   | -   | Gap     |

## Platform hardening

| Requirement                       | THA | FOR | ENT | UTI | BLO | COS | SEC | VLT | CLD | STD | CAT | Status  |
|-----------------------------------|-----|-----|-----|-----|-----|-----|-----|-----|-----|-----|-----|---------|
| TLS enforced by default           | -   | -   | -   | -   | -   | -   | -   | -   | -   | -   | ●   | Covered |
| Metadata encrypted at rest        | -   | -   | -   | -   | -   | ●   | -   | ●   | -   | ●   | -   | Covered |
| Master key rotation               | -   | -   | -   | -   | -   | -   | -   | ●   | -   | ●   | -   | Covered |
| Non-extractable key enforcement   | -   | -   | -   | -   | -   | -   | ●   | -   | ●   | ●   | -   | Covered |
| Request bounds and DoS resistance | -   | -   | -   | -   | -   | -   | -   | -   | -   | -   | ●   | Partial |
| Secrets kept out of configuration | -   | -   | -   | -   | -   | -   | -   | -   | -   | -   | ●   | Covered |
| Hardened service                  | -   | -   | -   | -   | -   | -   | -   | -   | -   | -   | ●   | Covered |
| Sealed startup with quorum unseal | -   | -   | -   | -   | -   | -   | -   | ●   | -   | -   | -   | Partial |

## What the columns add up to

*Read this as a description of the research, not of the market. A source with few marks is one whose documentation I read less of, not a product with fewer features.*

| Source                                                   | Requirements evidenced | Share of 82 | Kind                 |
|----------------------------------------------------------|------------------------|-------------|----------------------|
| THA — Thales CipherTrust Manager                         | 26                     | 31 %        | Vendor documentation |
| FOR — Fortanix Data Security Manager                     | 11                     | 13 %        | Vendor documentation |
| ENT — Entrust KeyControl                                 | 18                     | 21 %        | Vendor documentation |
| UTI — Utimaco Enterprise Secure Key Manager              | 16                     | 19 %        | Vendor documentation |
| BLO — Bloombase KeyCastle                                | 16                     | 19 %        | Vendor documentation |
| COS — Cosmian / Eviden KMS                               | 30                     | 36 %        | Vendor documentation |
| SEC — Securosys CyberVault KMS                           | 27                     | 32 %        | Vendor documentation |
| VLT — HashiCorp Vault                                    | 30                     | 36 %        | Vendor documentation |
| CLD — AWS KMS / Azure Managed HSM / Google Cloud KMS     | 13                     | 15 %        | Vendor documentation |
| STD — NIST SP 800-57, SP 800-152, OASIS KMIP 2.1 and 3.0 | 26                     | 31 %        | Standard             |
| CAT — Category baseline — no source named it             | 10                     | 12 %        | Category baseline    |

### Requirements carried only by the category baseline: 10 of 82

These are the rows to challenge first if the requirement list is ever disputed. Each is defensible as ordinary practice, but none was named by a vendor or a standard in the research behind the matrix.

- External audit anchoring
- Zero-downtime certificate rotation
- Rolling upgrades
- Health and readiness probes
- Structured logging
- Configuration-driven deployment
- TLS enforced by default
- Request bounds and DoS resistance
- Secrets kept out of configuration
- Hardened service

### What would make this stronger

- A hands-on evaluation of one or two products, which would turn this provenance table into a genuine capability comparison.
- The vendors' administration guides rather than their marketing pages — the former say what a product does, the latter what it advertises.
- An analyst grid, which would add an independent view of the category rather than each vendor's own.
- Direct access to four of the vendors' documentation sites. Bloombase, Cosmian, Securosys and HashiCorp were researched through indexed summaries of their pages because the network policy where this document is built blocks all four domains — so their columns are thinner than the reading would otherwise support.